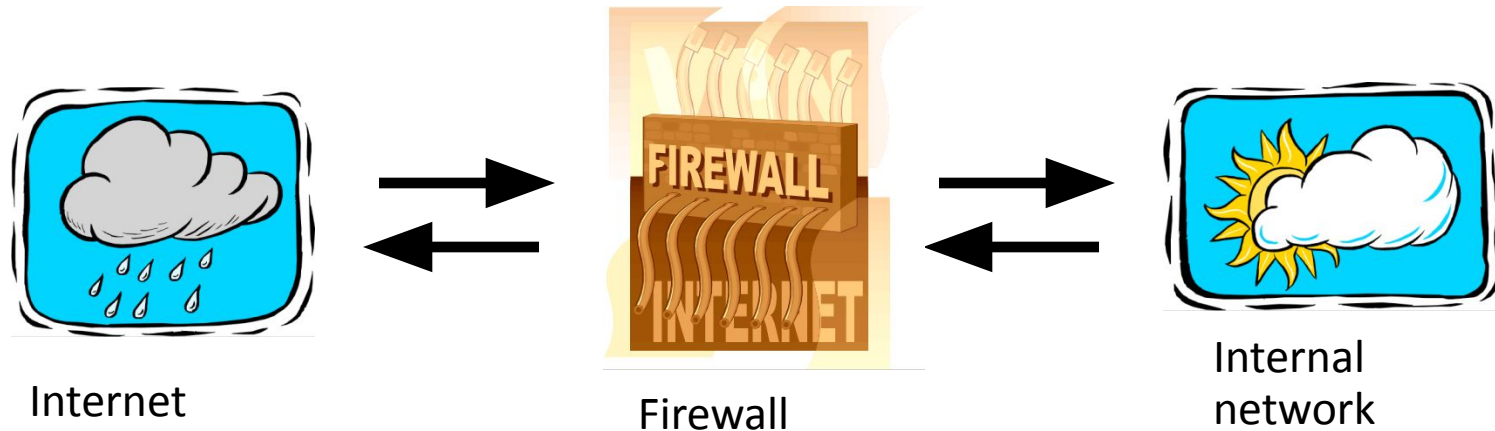


Firewalls



Firewalls



- Firewall must determine what to let in to internal network and/or what to let out
- **Access control** for the network

Firewall as Secretary

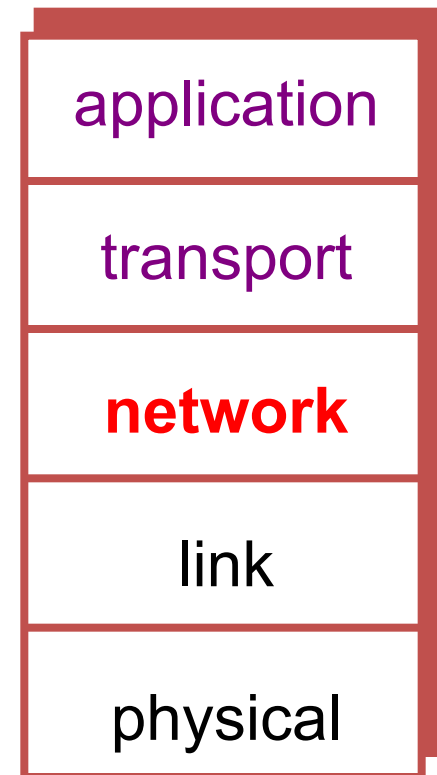
- A firewall is like a **secretary**
- To meet with an executive
 - First contact the secretary
 - Secretary decides if meeting is reasonable
 - Secretary filters out many requests
- You want to meet chair of CS department?
 - Secretary does some filtering
- You want to meet President of US?
 - Secretary does lots of filtering!

Firewall Terminology

- No standard terminology
- Types of firewalls
 - **Packet filter** —works at network layer
 - **Stateful packet filter** —transport layer
 - **Application proxy** —application layer
 - Personal firewall —for single user, home network, etc.

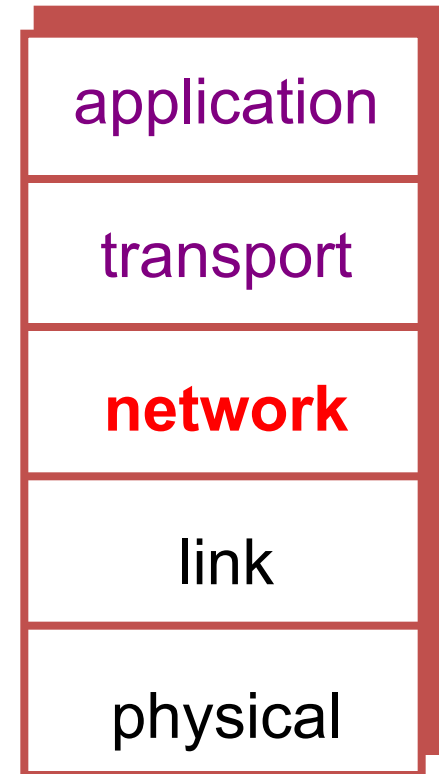
Packet Filter

- Operates at network layer
- Can filters based on
 - Source IP address
 - Destination IP address
 - Source Port
 - Destination Port
 - Flag bits (SYN, ACK, etc.)
 - Egress or ingress



Packet Filter

- Advantage
 - Speed
- Disadvantages
 - No state
 - Cannot see TCP connections
 - Blind to application data



Packet Filter

- Configured via Access Control Lists (ACLs)
 - Different meaning of ACL than previously

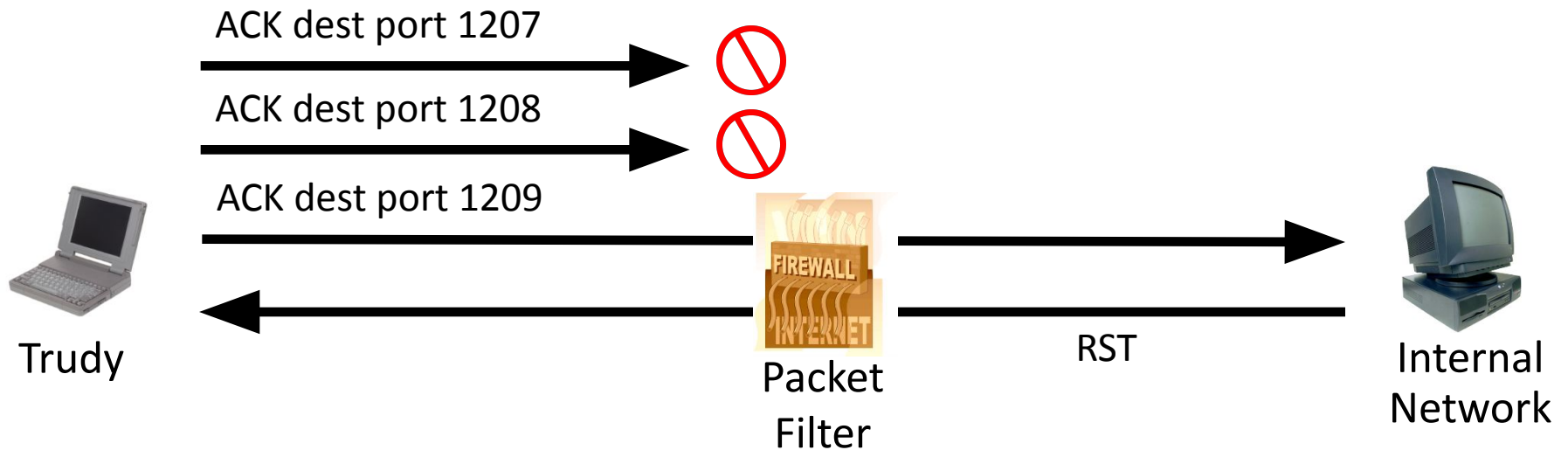
Action	Source IP	Dest IP	Source Port	Dest Port	Protocol	Flag Bits
Allow	Inside	Outside	Any	80	HTTP	Any
Allow	Outside	Inside	80	> 1023	HTTP	ACK
Deny	All	All	All	All	All	All

- ❑ Intention is to restrict incoming packets to Web responses

TCP ACK Scan

- Attacker sends packet with ACK bit set, **without** prior 3-way handshake
- Violates TCP/IP protocol
- ACK packet pass thru packet filter firewall
 - Appears to be part of an ongoing connection
- RST sent by recipient of such packet
- Attacker scans for open ports thru firewall

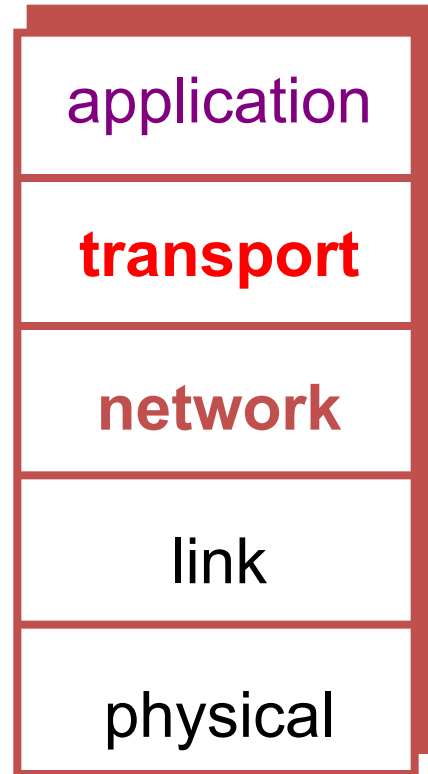
TCP ACK Scan



- Attacker knows port 1209 open thru firewall
- A **stateful packet filter** can prevent this (next)
 - Since ACK scans not part of established connections

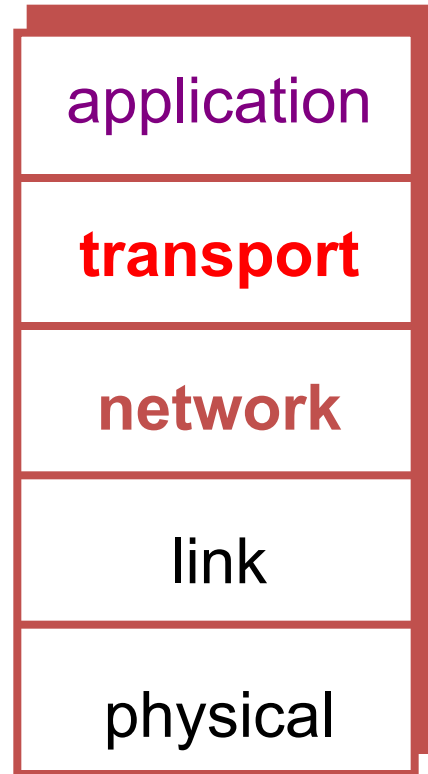
Stateful Packet Filter

- Adds **state** to packet filter
- Operates at transport layer
- Remembers TCP connections and flag bits
- Can even remember UDP packets (e.g., DNS requests)



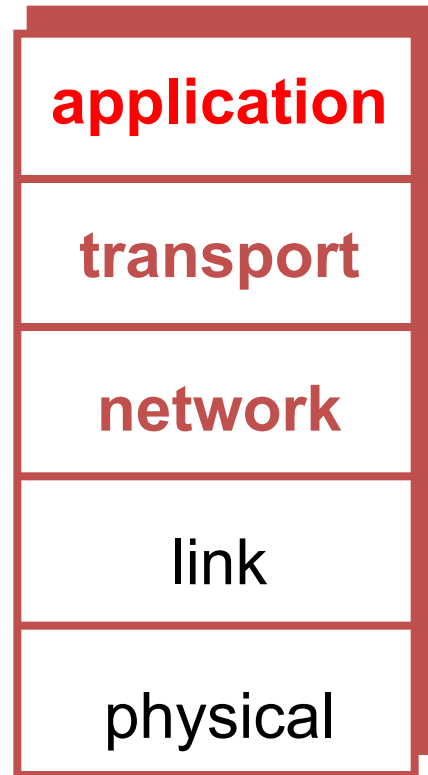
Stateful Packet Filter

- Advantages
 - Can do everything a packet filter can do plus...
 - Keep track of ongoing connections
- Disadvantages
 - Cannot see application data
 - Slower than packet filtering



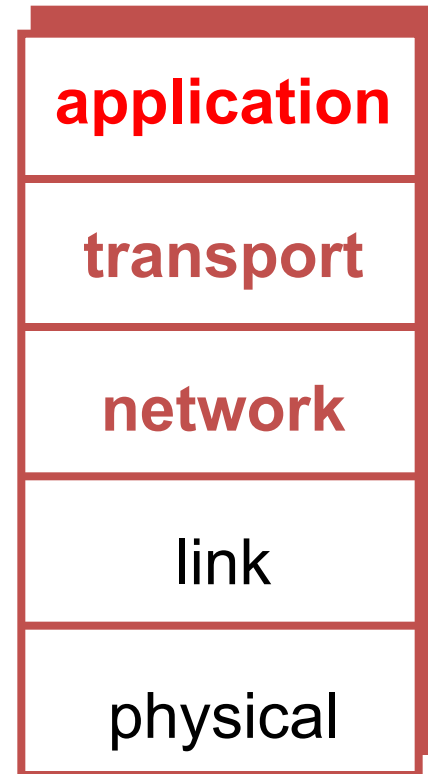
Application Proxy

- A **proxy** is something that acts on your behalf
- Application proxy looks at incoming application data
- Verifies that data is safe before letting it in



Application Proxy

- Advantages
 - Complete view of connections and applications data
 - Filter bad data at application layer (viruses, Word macros)
 - Deep packet inspection vs header inspection
- Disadvantage
 - Speed
 - Single point of failure



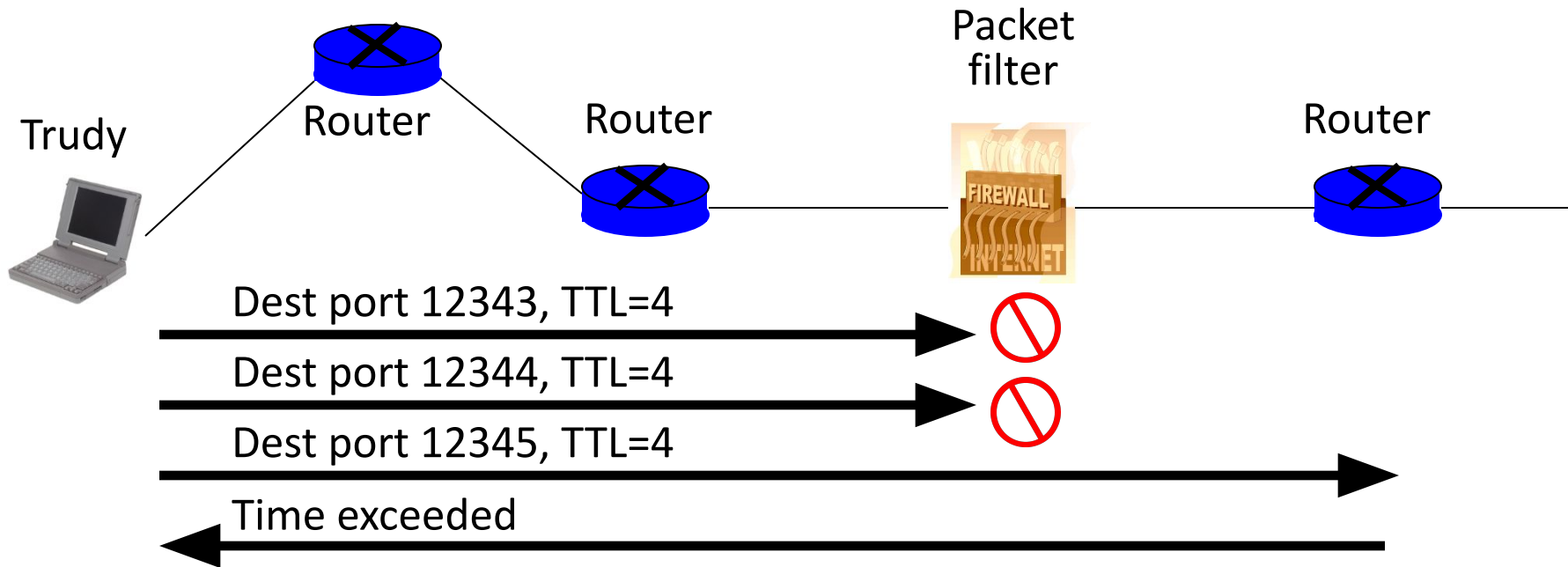
Application Proxy

- Creates a new packet before sending it thru to internal network
- Attacker must talk to **proxy** and convince it to forward message
- Proxy has complete view of connection
- Prevents some attacks stateful packet filter cannot — see next slides

Firewalk

- Tool to scan for open ports thru firewall
- Known: IP address of firewall and IP address of one system inside firewall
 - TTL set to 1 more than number of hops to firewall and set destination port to N
 - If firewall does not let thru data on port N, no response
 - If firewall allows data on port N thru firewall, get time exceeded error message

Firewalk and Proxy Firewall



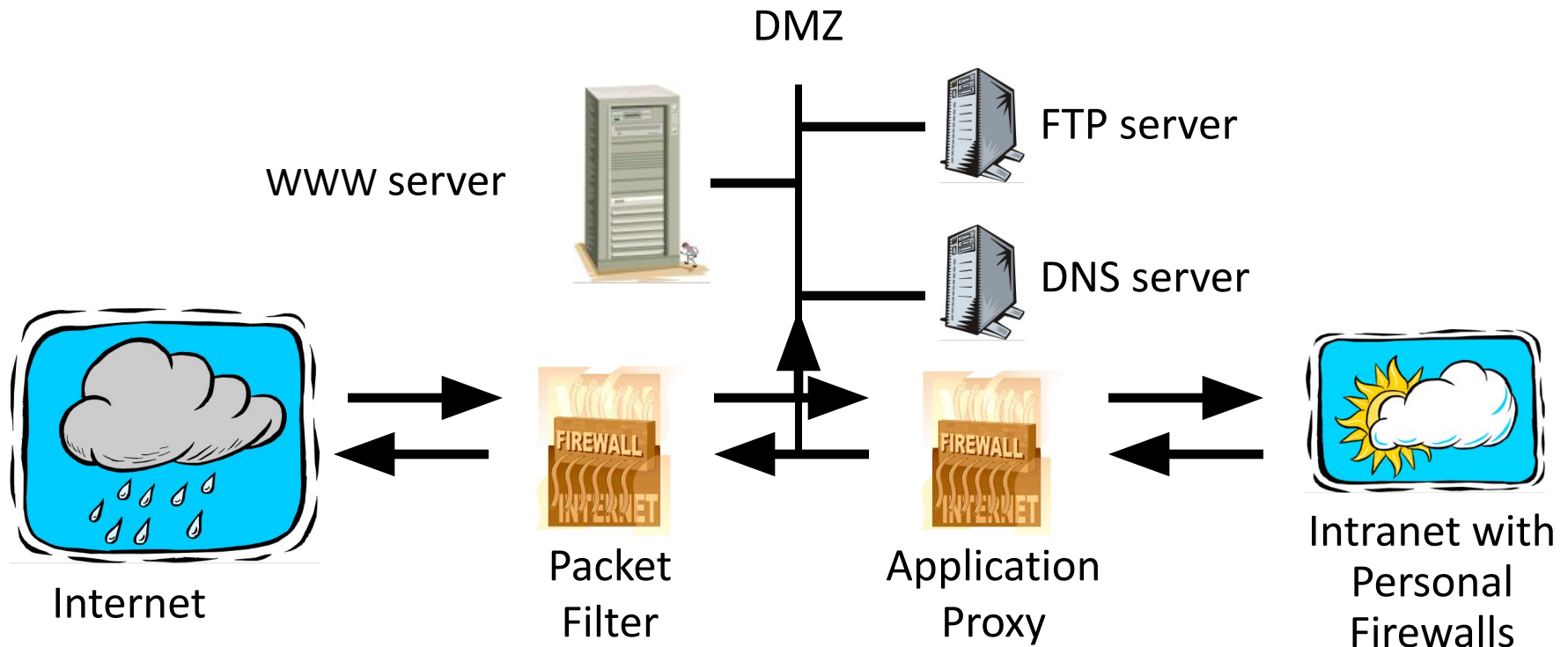
- This will **not** work thru an application proxy
- The proxy creates a new packet, destroys old TTL

Personal Firewall

- To protect one user or home network
- Can use any of the methods
 - Packet filter
 - Stateful packet filter
 - Application proxy

Firewalls and Defense in Depth

- Example security architecture



Intrusion Detection Systems

Intrusion Prevention

- Want to keep bad guys out
- **Intrusion prevention** is a traditional focus of computer security
 - Authentication is to prevent intrusions
 - Firewalls a form of intrusion prevention
 - Virus defenses also intrusion prevention
- Comparable to locking the door on your car

Intrusion Detection

- In spite of intrusion prevention, bad guys will sometime get into system
- Intrusion detection systems (IDS)
 - Detect attacks
 - Look for “unusual” activity
- IDS developed out of log file analysis
- IDS is currently a very **hot** research topic
- How to respond when intrusion detected?
 - We don’t deal with this topic here

Intrusion Detection Systems

- Who is likely intruder?
 - May be outsider who got thru firewall
 - May be evil insider
- What do intruders do?
 - Launch well-known attacks
 - Launch variations on well-known attacks
 - Launch new or little-known attacks
 - Use a system to attack other systems
 - Etc.

IDS

- Intrusion detection **approaches**
 - Signature-based IDS
 - Anomaly-based IDS
- Intrusion detection **architectures**
 - Host-based IDS
 - Network-based IDS
- Most systems can be classified as above
 - In spite of marketing claims to the contrary!

Host-based IDS

- Monitor activities on hosts for
 - Known attacks or
 - Suspicious behavior
- Designed to detect attacks such as
 - Buffer overflow
 - Escalation of privilege
- Little or no view of network activities

Network-based IDS

- Monitor activity on the network for
 - Known attacks
 - Suspicious network activity
- Designed to detect attacks such as
 - Denial of service
 - Network probes
 - Malformed packets, etc.
- Can be some overlap with firewall
- Little or no view of host-base attacks
- Can have both host and network IDS

Signature Detection Example

- Failed login attempts may indicate password cracking attack
- IDS could use the rule “N failed login attempts in M seconds” as **signature**
- If N or more failed login attempts in M seconds, IDS warns of attack
- Note that the warning is specific
 - Admin knows what attack is suspected
 - Admin can verify attack (or false alarm)

Signature Detection

- Suppose IDS warns whenever N or more failed logins in M seconds
- Must set N and M so that false alarms not common
- Can do this based on normal behavior
- But if attacker knows the signature, he can try $N-1$ logins every M seconds!
- In this case, signature detection slows the attacker, but might not stop him

Signature Detection

- Many techniques used to make signature detection more robust
- Goal is usually to detect “almost signatures”
- For example, if “about” N login attempts in “about” M seconds
 - Warn of possible password cracking attempt
 - What are reasonable values for “about”?
 - Can use statistical analysis, heuristics, other
 - Must take care not to increase false alarm rate

Signature Detection

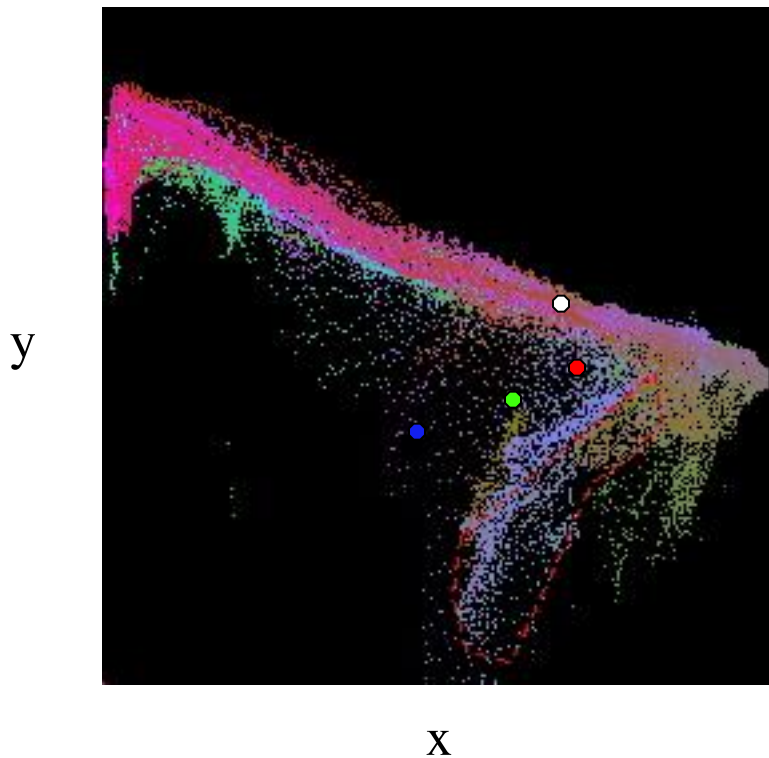
- Advantages of signature detection
 - Simple
 - Detect known attacks
 - Know which attack at time of detection
 - Efficient (if reasonable number of signatures)
- Disadvantages of signature detection
 - Signature files must be kept up to date
 - Number of signatures may become large
 - Can only detect known attacks
 - Variation on known attack may not be detected

Anomaly Detection

- Anomaly detection systems look for unusual or abnormal behavior
- There are (at least) two challenges
 - What is normal for this system?
 - How “far” from normal is abnormal?
- Statistics is obviously required here!
 - The **mean** defines normal
 - The **variance** indicates how far abnormal lives from normal

What is Normal?

- Consider the scatterplot below



- ☐ White dot is “normal”
- ☐ Is red dot normal?
- ☐ Is green dot normal?
- ☐ How abnormal is the blue dot?
- ☐ Stats can be tricky!

How to Measure Normal?

- How to measure normal?
 - Must measure during “representative” behavior
 - Must not measure during an attack...
 - ...or else attack will seem normal!
 - Normal is statistical mean
 - Must also compute variance to have any reasonable chance of success

How to Measure Abnormal?

- Abnormal is relative to some “normal”
 - Abnormal indicates possible attack
- Statistical discrimination techniques:
 - Bayesian statistics
 - Linear discriminant analysis (LDA)
 - Quadratic discriminant analysis (QDA)
 - Neural nets, hidden Markov models, etc.
- Fancy modeling techniques also used
 - Artificial intelligence
 - Artificial immune system principles
 - Many others!

Anomaly Detection (1)

- Suppose we monitor use of three commands:
open, read, close
- Under normal use we observe that Alice
open,read,close,open,open,read,close,...
- Of the six possible ordered pairs, four pairs are
“normal” for Alice:
(open,read), (read,close), (close,open), (open,open)
- Can we use this to identify unusual activity?

Anomaly Detection (1)

- We monitor use of the three commands
open, read, close
- If the ratio of abnormal to normal pairs is “too high”,
warn of possible attack
- Could improve this approach by
 - Also using expected frequency of each pair
 - Use more than two consecutive commands
 - Include more commands/behavior in the model
 - More sophisticated statistical discrimination

Anomaly Detection (2)

- Over time, Alice has accessed file F_n at rate H_n

H_0	H_1	H_2	H_3
.10	.40	.40	.10

- Recently, Alice has accessed file F_n at rate A_n

A_0	A_1	A_2	A_3
.10	.40	.30	.20

- Is this “normal” use?
- We compute $S = (H_0 - A_0)^2 + (H_1 - A_1)^2 + \dots + (H_3 - A_3)^2 = .02$
- And consider $S < 0.1$ to be normal, so this is normal
- Problem: How to account for use that varies over time?

Anomaly Detection (2)

- To allow “normal” to adapt to new use, we update long-term averages as

$$H_n = 0.2A_n + 0.8H_{n-1}$$

- Then H_0 and H_1 are unchanged, $H_2 = .2 * .3 + .8 * .4 = .38$ and $H_3 = .2 * .2 + .8 * .1 = .12$
- And the long term averages are updated as

H_0	H_1	H_2	H_3
.10	.40	.38	.12

Anomaly Detection (2)

- The updated long term average is

H_0	H_1	H_2	H_3
.10	.40	.38	.12

- New observed rates are...

A_0	A_1	A_2	A_3
.10	.30	.30	.30

- Is this normal use?
- Compute $S = (H_0 - A_0)^2 + \dots + (H_3 - A_3)^2 = .0488$
- Since $S = .0488 < 0.1$ we consider this normal
- And we again update the long term averages by $H_n = 0.2A_n + 0.8H_n$

Anomaly Detection (2)

- The starting averages were

H_0	H_1	H_2	H_3
.10	.40	.40	.10

- ❑ After 2 iterations, the averages are

H_0	H_1	H_2	H_3
.10	.38	.364	.156

- ❑ The stats slowly evolve to match behavior
- ❑ This reduces false alarms and work for admin
- ❑ But also opens an avenue for attack...
- ❑ Suppose Trudy **always** wants to access F_3
- ❑ She can convince IDS this is normal for Alice!

Anomaly Detection (2)

- To make this approach more robust, must also incorporate the variance
- Can also combine N stats as, for example,
$$T = (S_1 + S_2 + S_3 + \dots + S_N) / N$$

to obtain a more complete view of “normal”
- Similar (but more sophisticated) approach is used in IDS known as NIDES
- NIDES includes anomaly and signature IDS

Anomaly Detection Issues

- System constantly evolves and so must IDS
 - Static system would place huge burden on admin
 - But evolving IDS makes it possible for attacker to (slowly) convince IDS that an attack is normal!
 - Attacker may win simply by “going slow”
- What does “abnormal” really mean?
 - Only that there is possibly an attack
 - May not say anything specific about attack!
 - How to respond to such vague information?
- Signature detection tells exactly which attack

Anomaly Detection

- Advantages
 - Chance of detecting unknown attacks
 - May be more efficient (since no signatures)
- Disadvantages
 - Today, cannot be used alone
 - Must be used with a signature detection system
 - Reliability is unclear
 - May be subject to attack
 - Anomaly detection indicates something unusual
 - But lack of specific info on possible attack!

Anomaly Detection: The Bottom Line

- Anomaly-based IDS is active research topic
- Many security professionals have very high hopes for its ultimate success
- Often cited as key future security technology
- Hackers are not convinced!
 - Title of a talk at Defcon 11: “Why Anomaly-based IDS is an Attacker’s Best Friend”
- Anomaly detection is difficult and tricky
- Is anomaly detection as hard as AI?